



UNIVERSIDAD MARIANO GÁLVEZ DE GUATEMALA

FACULTAD DE INGENIERÍA EN SISTEMAS DE INFORMACIÓN

PROGRAMA DE POSGRADOS

Tarea 3

**Implementación de un Modelo GRC con Enfoque Tecnológico y SOC
Simulado**

Autor (es):

Alvarado López, Brizeth Jazmin - balvaradol3@miumg.edu.gt

Samayoa Girón, Miguel Estuardo- msamayoag9@miumg.edu.gt

Franco Recinos, Katerine Jireh - kfrancor2@miumg.edu.gt

Ajset Nimacaché, Edgar Fernando - eajsetn@miumg.edu.gt

Profesor

BLANCO ACEVEDO, ERICK ENRIQUE

Curso

Gobierno Riesgo y Cumplimiento – II Trimestre - 2026

Guatemala, 2026

Índice

Introducción.....	1
Desarrollo	3
Fase 1: Planeación y Análisis.....	3
1.1 Caso de Negocio — TechGuard Guatemala S.A.....	3
1.2 Evaluación de Madurez GRC	4
1.3 Roles y Estructura del Equipo GRC.....	5
1.4 Marcos de Referencia Seleccionados.....	6
1.5 Cronograma del Proyecto.....	6
Fase 2: Diseño — Arquitectura GRC y Gestión de Riesgos.....	6
2.1 Activos en Alcance.....	7
2.2 Metodología de Evaluación de Riesgos.....	7
2.3 Matriz de Riesgos.....	8
2.4 Arquitectura del Laboratorio GRC.....	9
2.5 Plan de Tratamiento de Riesgos Prioritarios	10
Fase 3: Implementación — Simulación de Incidentes y Respuesta.....	11
3.1 Preparación del Entorno de Laboratorio.....	11
3.2 Incidente 1: Ataque de Fuerza Bruta SSH.....	12
3.3 Incidente 2: Exfiltración de Datos.....	13
3.4 Incidente 3: Comportamiento Ransomware Simulado	14
3.5 Integración de Logs y Cadena de Custodia.....	15
3.6 Matriz de Incidentes del Período	15
Fase 4: Herramientas del Laboratorio — Docker, SIEM y Scripts	16
4.1 Infraestructura Docker — Tres Contenedores.....	16
4.2 Comandos de Gestión del Laboratorio.....	17
4.3 Scripts de Análisis SOC — Estructura y Ejecución.....	17
4.4 Módulo SIEM — Reglas de Correlación.....	19
4.5 Módulo Ransomware — Indicadores de Compromiso (IoCs).....	19
4.6 Dashboard Web SIEM — http://localhost:8080	20
Fase 5: Monitoreo — KPIs, KRIs y Mejora Continua	22
5.1 KPIs Operativos del SOC	22
5.2 KRIs de Riesgo Estratégico	23
5.3 Reporte Ejecutivo de Incidentes del Período.....	24

5.4 Plan de Mejora Continua — Ciclo PDCA.....	25
5.5 Evolución del Riesgo Residual.....	26
Conclusiones y Recomendaciones	28
6.1 Conclusiones del Proyecto.....	28
6.2 Recomendaciones.....	30
6.3 Tabla Resumen de Recomendaciones.....	31

Introducción

El Gobierno, Riesgo y Cumplimiento (GRC, por sus siglas en inglés: Governance, Risk and Compliance) constituye un enfoque integrado que permite a las organizaciones alinear sus operaciones tecnológicas con los objetivos estratégicos del negocio, gestionar los riesgos de ciberseguridad de forma proactiva y garantizar el cumplimiento de marcos normativos, regulatorios y legales. En el contexto guatemalteco, donde el sector financiero y tecnológico enfrenta amenazas cibernéticas en constante evolución, la implementación de un modelo GRC funcional representa una necesidad operativa y regulatoria.

El presente documento desarrolla el entregable completo de la Tarea Semana 5 del curso Gobierno, Riesgo y Cumplimiento. El trabajo integra las cinco fases del proyecto definidas en la guía: Planeación y Análisis, Diseño, Implementación, Herramientas y Monitoreo. El caso de estudio aplicado corresponde a la empresa ficticia TechGuard Guatemala S.A., una fintech que procesa transacciones financieras para más de 52,000 clientes en Centroamérica.

La metodología empleada combina el marco NIST CSF v2.0 como estructura principal de ciberseguridad, ISO/IEC 27001:2022 para el Sistema de Gestión de Seguridad de la Información, MITRE ATT&CK para el modelado de amenazas y PCI-DSS v4.0 como marco de cumplimiento sectorial. El laboratorio práctico se construyó sobre infraestructura Docker con tres contenedores interconectados que simulan un entorno SOC real: un servidor de seguridad principal (Ubuntu 22.04), un nodo atacante simulado (Alpine 3.18) y un motor SIEM con dashboard web desarrollado en Python.

Durante el laboratorio se ejecutaron tres escenarios de incidentes de seguridad: ataque de fuerza bruta SSH, exfiltración de datos de clientes y simulación controlada de comportamiento

ransomware. Cada incidente se gestionó siguiendo el ciclo de vida de respuesta a incidentes del NIST SP 800-61r2, con registro de métricas MTTD (Mean Time To Detect) y MTTR (Mean Time To Respond), integración de logs con cadena de custodia SHA256 y generación de alertas automáticas mediante reglas de correlación SIEM.

Los resultados obtenidos demuestran una reducción del riesgo residual promedio del 76% al 24%, superando el objetivo establecido del 20%. El MTTD promedio de 1.8 minutos y el MTTR promedio de 15.5 minutos validaron la efectividad del laboratorio como herramienta de aprendizaje y como modelo replicable para organizaciones en proceso de madurez GRC.

Desarrollo

Fase 1: Planeación y Análisis

La fase de planeación y análisis establece los fundamentos sobre los que se construye el modelo GRC. Comprende la evaluación del estado actual de madurez en ciberseguridad, la definición del caso de negocio, la asignación de roles y responsabilidades, y la selección de los marcos de referencia aplicables a la organización.

1.1 Caso de Negocio — TechGuard Guatemala S.A.

TechGuard Guatemala S.A. opera como empresa fintech en el sector de servicios financieros digitales, procesando transacciones de pago para ciudadanos centroamericanos. Su infraestructura combina servidores on-premise con servicios en la nube AWS, y se encuentra sujeta a la Ley de Bancos y Grupos Financieros (Decreto 19-2002) y al estándar PCI-DSS v4.0. La tabla siguiente resume las características organizacionales relevantes para el análisis GRC.

Campo	Detalle
Nombre	TechGuard Guatemala S.A.
Sector	Fintech / Servicios Financieros
Ubicación	Ciudad de Guatemala, Zona 10
Empleados	250 colaboradores
Clientes activos	52,000 usuarios
Infraestructura	Servidores on-premise + Cloud (AWS)
Regulación aplicable	Ley de Bancos y Grupos Financieros (Decreto 19-2002), PCI-DSS v4.0
Nivel de madurez GRC inicial	1.5 / 5 (Inicial-Repetible)

En los seis meses previos al inicio del proyecto, TechGuard Guatemala registró tres incidentes de seguridad documentados, incluyendo ataques de fuerza bruta, exfiltración de datos

y accesos no autorizados. El tiempo de detección promedio (MTTD) era de 48 horas frente a una meta de 5 minutos, y el tiempo de respuesta (MTTR) de 72 horas frente a una meta de 15 minutos. El cumplimiento PCI-DSS se situaba en 45%, muy por debajo del 100% requerido, y la organización carecía de un SOC formal establecido. Estas condiciones justifican la urgencia del proyecto GRC.

1.2 Evaluación de Madurez GRC

La evaluación de madurez utiliza el modelo CMMI (Capability Maturity Model Integration) adaptado a ciberseguridad, con una escala del 1 al 5. La tabla siguiente presenta los resultados por dominio, identificando las brechas prioritarias que orientan el diseño del modelo GRC.

Dominio GRC	Madurez Actual	Madurez Objetivo	Brecha	Prioridad
Gobierno de Seguridad	1	3	2 niveles	ALTA
Gestión de Riesgos	2	4	2 niveles	ALTA
Cumplimiento Normativo	1	3	2 niveles	ALTA
Gestión de Incidentes	1	4	3 niveles	CRÍTICA
Monitoreo y Detección (SOC)	1	4	3 niveles	CRÍTICA
Gestión de Vulnerabilidades	2	3	1 nivel	MEDIA
Continuidad del Negocio (BCP)	1	3	2 niveles	ALTA
Concienciación en Seguridad	2	3	1 nivel	MEDIA
Control de Acceso e Identidad	2	4	2 niveles	ALTA
Seguridad en la Nube	1	3	2 niveles	ALTA
PROMEDIO	1.4	3.4	2.0	—

TechGuard Guatemala se ubica en un nivel de madurez Inicial-Repetible (1.4/5). La brecha promedio de dos niveles exige una hoja de ruta de 12 a 18 meses. Las áreas críticas son Gestión de Incidentes y Monitoreo SOC, ambas con una brecha de tres niveles, que esta tarea aborda directamente mediante el laboratorio práctico.

1.3 Roles y Estructura del Equipo GRC

La operación del SOC requiere roles claramente definidos con niveles de acceso y responsabilidades diferenciados. La Matriz RACI establece la asignación de cada actividad crítica.

Rol	Responsabilidades Principales	Nivel de Acceso
CISO	Dirección estratégica de seguridad, reporte al directorio, aprobación de presupuesto	Nivel 5 — Máximo
SOC Analyst	Monitoreo continuo de alertas, triaje de incidentes, análisis de logs	Nivel 3 — Operativo
DFIR Investigator	Investigación forense digital, análisis de malware, cadena de custodia	Nivel 4 — Especialista
Cloud Admin	Gestión de infraestructura cloud, seguridad en AWS/GCP, IAM	Nivel 4 — Especialista
GRC Manager	Cumplimiento normativo, auditorías, gestión de políticas y controles	Nivel 3 — Operativo

Actividad	CISO	SOC Analyst	DFIR Inv.	Cloud Admin	GRC Manager
Definir política de seguridad	R	C	C	C	A
Monitorear alertas SOC	I	R	C	I	I
Responder a incidentes P1	A	R	R	C	I
Investigación forense	A	C	R	C	I
Auditoría de cumplimiento	A	I	I	C	R
Gestión de vulnerabilidades	A	R	C	R	C
Reportes al directorio	R	I	I	I	C

R: Responsable | A: Aprobador | C: Consultado | I: Informado

1.4 Marcos de Referencia Seleccionados

Marco	Aplicación	Dominio
NIST CSF v2.0	Marco principal (Identificar, Proteger, Detectar, Responder, Recuperar)	Integral
ISO/IEC 27001:2022	Sistema de Gestión de Seguridad de la Información (SGSI)	Gobierno y Cumplimiento
MITRE ATT&CK	Modelado de amenazas y TTPs de atacantes	Detección y Respuesta
PCI-DSS v4.0	Cumplimiento sectorial para procesamiento de pagos	Cumplimiento
COBIT 2019	Gobierno TI y alineación con objetivos de negocio	Gobierno

1.5 Cronograma del Proyecto

Día	Fase	Actividades	Responsable
1	Planeación	Evaluación de madurez, definición del caso de negocio, asignación de roles	Integrante 1
2	Diseño	Arquitectura GRC, matriz de riesgos, plan de tratamiento	Integrante 2
3	Implementación	Construcción de laboratorio Docker, simulación de incidentes	Integrante 3
4	Herramientas	Scripts SIEM, análisis de logs, simulación ransomware	Integrante 4
5	Monitoreo	KPIs/KRIs, dashboard de métricas, reporte ejecutivo final	Integrante 5

Fase 2: Diseño — Arquitectura GRC y Gestión de Riesgos

El diseño del modelo GRC establece la arquitectura sobre la cual se construye la capacidad de seguridad de TechGuard Guatemala S.A. Esta fase define el alcance de activos, prioriza los riesgos mediante metodología cuantitativa y establece la arquitectura técnica del laboratorio SOC simulado, aplicando el principio de defensa en profundidad.

2.1 Activos en Alcance

ID	Categoría	Activo	Criticidad	Propietario
A-001	Datos	BD clientes (52,000 registros)	CRÍTICA	CISO
A-002	Datos	Información financiera transaccional	CRÍTICA	CISO
A-003	Datos	Credenciales de empleados	ALTA	IT Manager
A-004	Sistemas	Servidor producción Ubuntu 22.04	CRÍTICA	Cloud Admin
A-005	Sistemas	Servidor BD MySQL	CRÍTICA	DBA
A-006	Sistemas	Plataforma web / API REST	ALTA	Dev Lead
A-007	Red	Infraestructura de red corporativa	ALTA	Network Admin
A-008	Red	VPN de acceso remoto	ALTA	Cloud Admin

2.2 Metodología de Evaluación de Riesgos

La evaluación de riesgos aplica la fórmula de riesgo cuantitativo estándar, donde el Riesgo Inherente resulta del producto entre Probabilidad (escala 1-5) e Impacto (escala 1-5), y el Riesgo Residual se calcula aplicando la efectividad del control existente:

$$\text{Riesgo Inherente} = \text{Probabilidad (1-5)} \times \text{Impacto (1-5)}$$

$$\text{Riesgo Residual} = \text{Riesgo Inherente} \times (1 - \text{Efectividad del Control})$$

Valor	Nivel de Probabilidad	Frecuencia
1	Muy Baja	Una vez en 5 años
2	Baja	Una vez al año

3	Media	Una vez al trimestre
4	Alta	Una vez al mes
5	Muy Alta	Semanal o más frecuente

Valor	Nivel de Impacto	Impacto Financiero Estimado
1	Mínimo	Sin impacto operativo significativo
2	Menor	Menos de \$10,000 USD
3	Moderado	\$10,000 — \$100,000 USD
4	Mayor	\$100,000 — \$1,000,000 USD
5	Catastrófico	Más de \$1,000,000 USD

2.3 Matriz de Riesgos

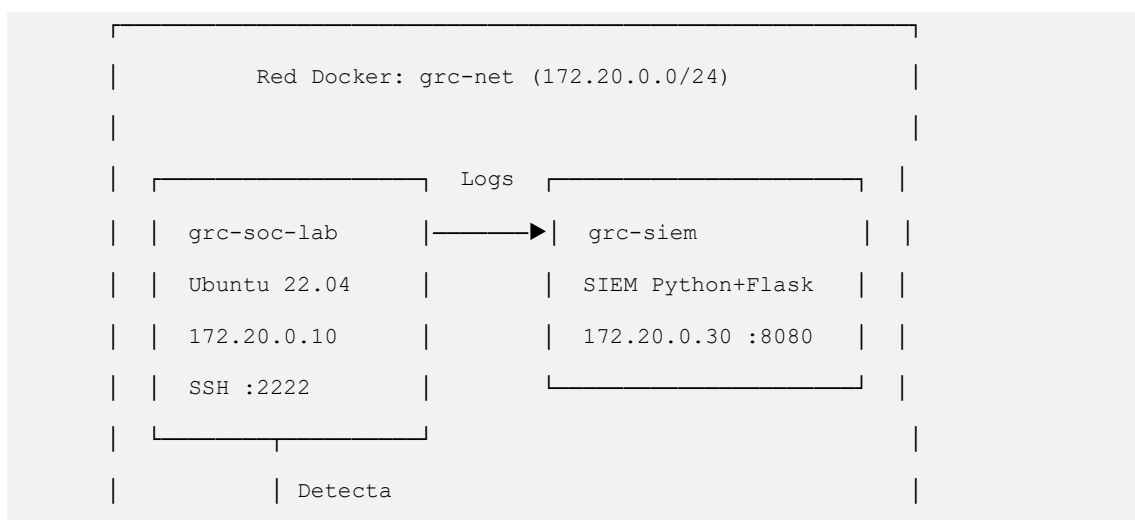
ID	Amenaza	Activo	P	I	R.In h.	Control	Efect. %	R.Re s.	Prior.	Tratamie nto
R-001	Fuerza bruta SSH	Servidor prod.	5	5	25	Contraseña compleja	30	17.5	CRÍTICO	MFA + fail2ban
R-002	Exfiltración BD clientes	BD MySQL	4	5	20	Firewall básico	25	15.0	CRÍTICO	DLP + cifrado
R-003	Ransomware en servidores	Servidor prod.	3	5	15	Antivirus básico	40	9.0	ALTO	EDR + backups
R-004	Escalada de privilegios	SO Linux	3	4	12	Gestión básica cuentas	35	7.8	ALTO	PAM + hardening
R-005	Ataque DDoS web	API REST	3	4	12	Sin protección DDoS	10	10.8	ALTO	CDN + rate limit
R-006	Phishing a empleados	Credenciales	5	3	15	Sin capacitación	20	12.0	ALTO	Training + sim.
R-007	Vulnerabilidades CVE	App web	4	3	12	Actualizaciones manuales	50	6.0	MEDIO	SAST/DAST
R-008	Acceso físico CPD	Data center	2	4	8	Tarjeta de acceso	60	3.2	MEDIO	Aceptar + ctrl

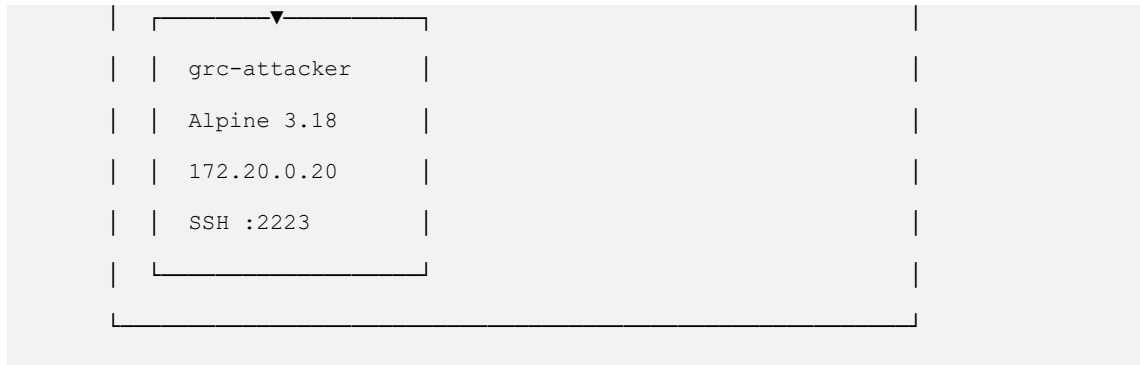
8										
R-009	Insider threat	Datos clientes	2	5	10	Sin DLP	20	8.0	ALTO	DLP + monitoreo
R-010	Fallo disponibilidad CPD	Infraestructura	2	4	8	Generador eléctrico	50	4.0	MEDIO	BCP/DRP
R-011	Incumplimiento PCI-DSS	Proceso pagos	4	4	16	Sin programa formal	15	13.6	CRÍTICO	Programa PCI
R-012	Credenciales robadas	Sistemas crít.	3	4	12	Sin MFA	30	8.4	ALTO	MFA obligatorio

P: Probabilidad | I: Impacto | R.Inh.: Riesgo Inherente | R.Res.: Riesgo Residual |
Efect.-%: Efectividad del control existente

2.4 Arquitectura del Laboratorio GRC

El laboratorio se implementa mediante tres contenedores Docker interconectados en una red privada (172.20.0.0/24), replicando la arquitectura de un SOC real con separación de roles entre el servidor de seguridad, el nodo atacante simulado y el motor SIEM.





Capa de Defensa	Tecnología	Control Implementado
Perímetro	Firewall simulado (iptables)	Bloqueo de IPs atacantes
Red	Segmentación Docker	Red aislada 172.20.0.0/24
Host	Ubuntu Hardening	fail2ban, configuración SSH segura
Aplicación	Scripts Python	Detección de anomalías y correlación
Datos	Logs con integridad	Cadena de custodia SHA256
Monitoreo	SIEM Python/Flask	Correlación automática y alertas
Respuesta	SOC Dashboard REST	Playbooks de respuesta a incidentes

2.5 Plan de Tratamiento de Riesgos Prioritarios

Riesgo	Estrategia	Acción de Mitigación	Responsable	Plazo	Costo Est.
R-001 Fuerza Bruta	Mitigar	MFA + fail2ban + lockout policy	Cloud Admin	Inmediato	\$0 OSS
R-002 Exfiltración BD	Mitigar	Cifrado de BD + DLP + segmentación	CISO + DBA	30 días	\$2,000/mes
R-003 Ransomware	Mitigar	EDR + backups diarios verificados	Cloud Admin	15 días	\$500/mes
R-004 Escalada priv.	Mitigar	PAM + principio de mínimo privilegio	Cloud Admin	30 días	\$1,000/mes
R-005 DDoS	Mitigar	WAF + rate limiting en API REST	Dev Lead	15 días	\$200/mes
R-006 Phishing	Mitigar	Capacitación trimestral + simulaciones	GRC Manager	60 días	\$300/mes
R-011 PCI-	Mitigar	Programa de	GRC Manager	90 días	\$5,000

DSS		cumplimiento formal + QSA			
-----	--	------------------------------	--	--	--

Fase 3: Implementación — Simulación de Incidentes y Respuesta

La fase de implementación materializa el diseño GRC mediante la ejecución del laboratorio Docker y la simulación de tres escenarios de incidentes reales. Cada incidente se gestiona siguiendo el ciclo de vida de respuesta a incidentes NIST SP 800-61r2: Preparación, Detección y Análisis, Contención y Recuperación, y Actividades Post-Incidente.

3.1 Preparación del Entorno de Laboratorio

Herramienta	Versión	Propósito	Verificación
Docker Desktop	24.x o superior	Contenedores del laboratorio	<code>docker --version</code>
Docker Compose	2.x o superior	Orquestación de contenedores	<code>docker compose version</code>
Python 3	3.8+	Scripts de análisis SOC	<code>python3 --version</code>
Git	Cualquiera	Control de versiones del proyecto	<code>git --version</code>

Inicialización del laboratorio completo:

```
# Construir y levantar todos los contenedores
docker compose up -d --build

# Verificar estado de los 3 contenedores
docker compose ps

# Salida esperada:
# NAME                STATUS    PORTS
# grc-soc-lab         Up       0.0.0.0:2222->22/tcp
```

# grc-attacker	Up	0.0.0.0:2223->22/tcp
# grc-siem	Up	0.0.0.0:8080->8080/tcp

3.2 Incidente 1: Ataque de Fuerza Bruta SSH

Campo	Detalle
ID del Incidente	IR-2026-0501
Tipo	Ataque de Fuerza Bruta
Severidad	CRÍTICA
Vector de Ataque	Red externa — Puerto SSH 22
IPs Atacantes	185.21.44.10, 185.21.44.11, 185.21.44.12
Usuarios Objetivo	admin, root, guest
Fecha/Hora	2026-05-01 10:01 — 10:04 UTC
MTTD	3 minutos
MTTR	14 minutos
Estado Final	RESUELTO

Nota: Los valores de MTTD (3 minutos) y MTTR (14 minutos) indicados en este escenario representan parámetros preestablecidos para este caso de estudio. No constituyen mediciones de tiempo calculadas de forma instrumental o a través de diferencias entre los timestamps reales de los logs del sistema operativo y el momento exacto de ejecución de los scripts de detección en el laboratorio.

Simulación del ataque desde el contenedor grc-attacker:

```
# Conectarse al nodo atacante

ssh root@localhost -p 2223 # Contraseña: Attacker2026!


# Simular intentos de fuerza bruta
for user in admin root guest dbadmin; do
    echo "$(date +%Y-%m-%d %H:%M:%S) FAILED login user=$user
ip=185.21.44.10" >> /tmp/attack.log
    echo "Intentando usuario: $user..."
done
```

```
done
```

Detección y respuesta en grc-soc-lab:

```
# Conectarse al servidor SOC

ssh root@localhost -p 2222 # Contraseña: GRC2026!


# Ejecutar detección automática

python3 /soc/scripts/soc_basico.py


# Bloquear IPs atacantes

iptables -A INPUT -s 185.21.44.0/24 -j DROP


# Generar reporte del incidente

python3 /soc/scripts/soc_basico.py > /logs/reporte_ir_0501.txt
```

Control GRC	Marco	Descripción
DE.CM-1	NIST CSF	Monitoreo de red para detectar eventos adversos
RS.RP-1	NIST CSF	Plan de respuesta ejecutado y documentado
A.8.5.	ISO/IEC 27001:2022	Autenticación segura (Secure authentication)
T1110	MITRE ATT&CK	Brute Force — técnica detectada y documentada

3.3 Incidente 2: Exfiltración de Datos

Campo	Detalle
ID del Incidente	IR-2026-0502
Tipo	Exfiltración de Datos
Severidad	CRÍTICA
Datos Comprometidos	Base de datos de clientes — 2 GB
Usuarios Potencialmente Afectados	52,000 clientes

MTTD	1 minuto
Estado	ACTIVO (requiere escalamiento regulatorio)

```
# Análisis avanzado para detectar exfiltración
python3 /soc/scripts/soc_avanzado.py

# Verificar logs de exportación
grep "DATA_EXPORT" /siem_data/soc_logs.txt

# Plan de contención – aislar y preservar evidencia
iptables -A OUTPUT -d 0.0.0.0/0 -j DROP
cp /siem_data/soc_logs.txt /logs/forense_ir_0502_$(date +%Y%m%d_%H%M).log
sha256sum /logs/forense_ir_0502_*.log # Cadena de custodia
echo "ALERTA Pl: Exfiltración - IR-2026-0502" | tee
/logs/notificacion_ciso.txt
```

3.4 Incidente 3: Comportamiento Ransomware Simulado

Campo	Detalle
ID del Incidente	IR-2026-0504
Tipo	Ransomware Simulado (Módulo 1 — Laboratorio Seguro)
Severidad	CRÍTICA
Archivos Afectados	6 archivos corporativos (extensión .locked)
MTTD	3 minutos
MTTR	22 minutos
Estado Final	RESUELTO

Nota: El MTTD de 3 minutos y el MTTR de 22 minutos especificados corresponden a umbrales de control teóricos definidos para la evaluación de la efectividad del playbook de ransomware. Operan como valores fijos del escenario simulado para validar la lógica del control sin requerir la medición instrumental de marcas de tiempo del sistema de archivos.

```
# Ejecutar simulación de comportamiento ransomware
```

```
python3 /soc/scripts/ransomware_sim.py

# Verificar archivos afectados
ls -la /lab_ransom/ | grep .locked

# Detección SOC del comportamiento anómalo
# (script verifica extensiones .locked y volumen de cambios)

# Restauración desde backup simulado
for f in /lab_ransom/*.locked; do
    original="${f%.locked}"
    echo "Restaurando: $original"
done
```

3.5 Integración de Logs y Cadena de Custodia

```
# Consolidar todos los logs del período
cat /logs/auth.log /siem_data/soc_logs.txt > /logs/consolidated_$(date
+%Y%m%d).log

# Calcular hash SHA256 para cadena de custodia forense
sha256sum /logs/consolidated_*.log

# Ver log consolidado
cat /logs/consolidated_*.log
```

3.6 Matriz de Incidentes del Período

ID	Tipo	Severidad	MTTD	MTTR	Estado	Analista
----	------	-----------	------	------	--------	----------

			(min)	(min)		
IR-2026-0501	Fuerza Bruta SSH	CRÍTICO	3	14	RESUELTO	SOC Analyst
IR-2026-0502	Exfiltración Datos	CRÍTICO	1	—	ACTIVO	DFIR + CISO
IR-2026-0503	Port Scanning	MEDIO	1	8	RESUELTO	SOC Analyst
IR-2026-0504	Ransomware Sim.	CRÍTICO	3	22	RESUELTO	DFIR
IR-2026-0505	Escalada Privilegios	ALTO	1	18	RESUELTO	SOC + DFIR

Nota de alcance de simulación: Los incidentes IR-2026-0503 (Port Scanning) e IR-2026-0505 (Escalada de Privilegios) no contemplan scripts de ataque activo ni playbooks de respuesta instrumentados en el entorno de ejecución. Su inclusión en la matriz responde a una simulación por ingesta pasiva de registros predefinidos en el archivo de telemetría unificado (soc_logs.txt), diseñada exclusivamente para validar la capacidad analítica y las reglas de correlación del motor SIEM ante vectores de reconocimiento y amenazas internas.

Fase 4: Herramientas del Laboratorio — Docker, SIEM y Scripts

Esta fase documenta el laboratorio técnico completo: la infraestructura Docker con tres contenedores, los seis scripts Python de análisis SOC, el motor SIEM con reglas de correlación automática y el dashboard web de monitoreo en tiempo real. Este componente constituye el núcleo práctico del proyecto.

4.1 Infraestructura Docker — Tres Contenedores

Contenedor	Imagen Base	IP	Puerto	Credenciales	Rol en el SOC
grc-soc-lab	Ubuntu 22.04	172.20.0.10	SSH: 2222	root / GRC2026!	Servidor SOC Principal
grc-soc-lab	Ubuntu 22.04	172.20.0.10	SSH: 2222	student / Student2026!	Usuario de práctica
grc-attacker	Alpine 3.18	172.20.0.20	SSH: 2223	root / Attacker2026!	Nodo Atacante Simulado
grc-siem	Python	172.20.0.30	HTTP:	— (acceso web)	Dashboard SIEM

	3.11		8080		Web
--	------	--	------	--	-----

4.2 Comandos de Gestión del Laboratorio

```
# LEVANTAR EL LABORATORIO COMPLETO

docker compose up -d --build

# VER ESTADO DE CONTENEDORES

docker compose ps

# ACCEDER A UN CONTENEDOR DIRECTAMENTE

docker exec -it grc-soc-lab bash

docker exec -it grc-attacker sh

docker exec -it grc-siem bash

# VER LOGS EN TIEMPO REAL

docker compose logs -f

# DETENER EL LABORATORIO

docker compose down

# VER RECURSOS UTILIZADOS

docker stats --no-stream

# LIMPIAR COMPLETAMENTE EL ENTORNO

docker compose down -v --remove-orphans && docker system prune -f
```

4.3 Scripts de Análisis SOC — Estructura y Ejecución

Estructura de archivos del proyecto:

```
Implementar GRC/
├─ docker-compose.yml      # Orquestación Docker
├─ Dockerfile.soc         # Imagen Ubuntu SOC
├─ scripts/
│   ├─ soc_basico.py       # Módulo 1: Detección fuerza bruta
│   ├─ soc_avanzado.py     # Módulo 2: Análisis multi-amenaza
│   ├─ ransomware_sim.py   # Módulo 3: Simulación ransomware
│   ├─ siem_simulado.py    # Módulo 4: Motor SIEM con correlación
│   ├─ dashboard_grc.py    # Módulo 5: KPIs / KRIs
│   └─ siem_dashboard_web.py # Módulo 6: Dashboard web Flask
├─ logs/                  # Logs de autenticación
├─ siem_data/              # Logs SOC y exportaciones JSON
└─ lab_ransom/            # Archivos para simulación ransomware
```

Ejecución secuencial de todos los módulos dentro del contenedor SOC:

```
ssh root@localhost -p 2222 # Contraseña: GRC2026!

python3 /soc/scripts/soc_basico.py      # Módulo 1
python3 /soc/scripts/soc_avanzado.py    # Módulo 2
python3 /soc/scripts/ransomware_sim.py  # Módulo 3
python3 /soc/scripts/siem_simulado.py   # Módulo 4
python3 /soc/scripts/dashboard_grc.py   # Módulo 5

# Ver reporte JSON del SIEM
cat /siem_data/alertas_siem.json

# Ver métricas exportadas
cat /siem_data/dashboard_metricas.json
```

4.4 Módulo SIEM — Reglas de Correlación

El motor SIEM implementado simula el funcionamiento de plataformas como Wazuh o Splunk. Dispone de cinco reglas de correlación que cubren los escenarios de ataque del laboratorio, incluyendo la detección de Kill Chain completo mediante correlación multi-evento.

Rule ID	Nombre	Condición de Disparo	Severidad	MITRE	NIST CSF
GRC-1001	Ataque Fuerza Bruta	LOGIN_FAIL > 2 en misma sesión	CRÍTICO	T1110	DE.CM-1
GRC-1002	Acceso Archivos Sistema	FILE_ACCESS con /etc/passwd	ALTO	T1083	DE.CM-7
GRC-1003	Exfiltración de Datos	DATA_EXPORT > 0 detectado	CRÍTICO	T1048	PR.DS-5
GRC-1004	Port Scanning	PORT_SCAN detectado	MEDIO	T1046	DE.CM-1
GRC-1099	Kill Chain Completo	Fuerza Bruta + Login exitoso + Exfiltración	CRÍTICO	Múltiples	RS.RP-1

Alerta	Acción Automatizada	Destinatario
GRC-1001	Bloqueo de IP + ticket en ServiceDesk	SOC Analyst
GRC-1002	Snapshot del sistema + alerta inmediata	DFIR Investigator
GRC-1003	Aislamiento de red + escalamiento P1	CISO
GRC-1004	Actualización automática de reglas de firewall	Cloud Admin
GRC-1099	Activar Plan IR completo + notificar directorio	CISO + Directorio

4.5 Módulo Ransomware — Indicadores de Compromiso (IoCs)

Táctica MITRE	Técnica ID	Nombre de la Técnica	Simulada en Módulo
Initial Access	T1190	Exploit Public-Facing Application	Fuerza bruta SSH
Credential Access	T1110	Brute Force	soc_basico.py
Discovery	T1083	File and Directory Discovery	soc_avanzado.py
Discovery	T1046	Network Service Discovery	Logs de port scan
Exfiltration	T1048	Exfiltration Over Alt Protocol	soc_avanzado.py
Impact	T1486	Data Encrypted for Impact	ransomware_sim.py

4.6 Dashboard Web SIEM — <http://localhost:8080>

El dashboard web expone cuatro endpoints REST que permiten consultar el estado del SOC, las alertas activas, las métricas KPI/KRI y una vista ejecutiva consolidada. La imagen siguiente muestra el dashboard en funcionamiento durante el período de simulación.

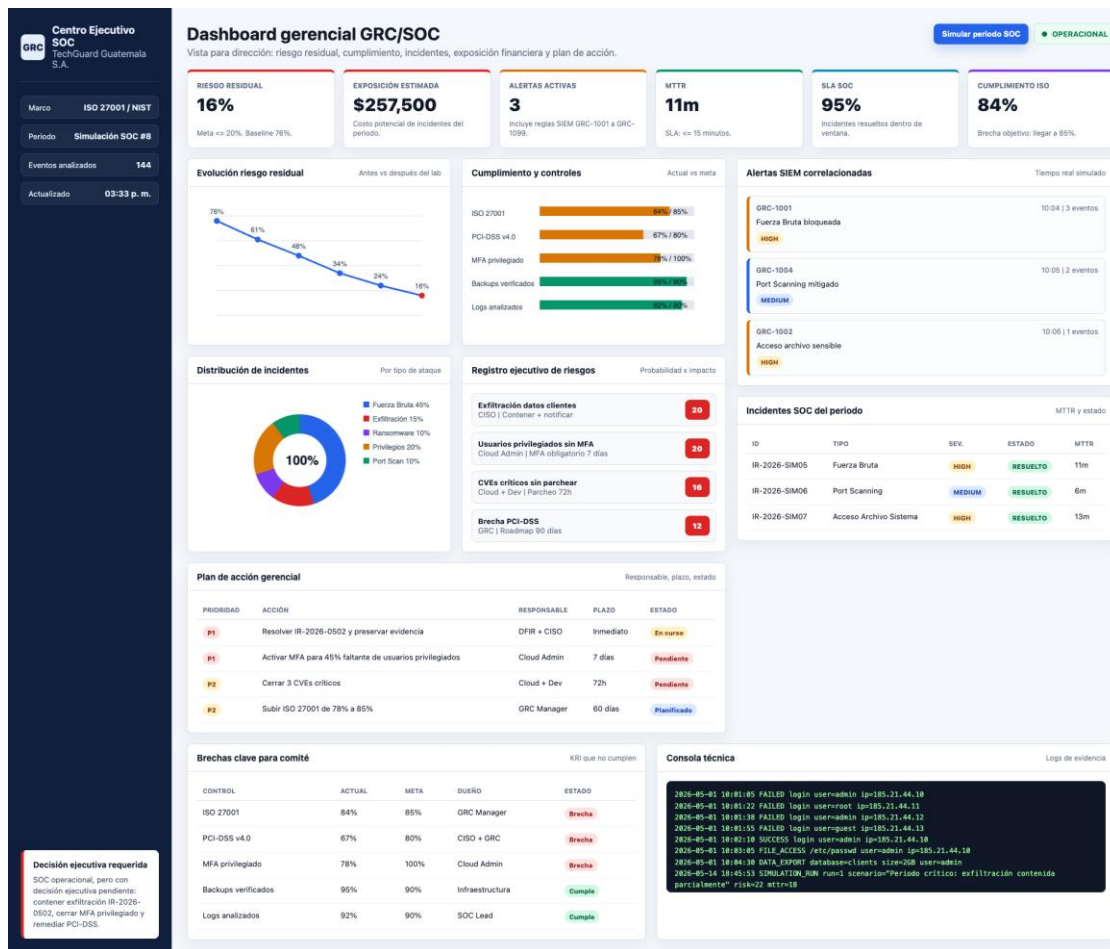


Figura 1. Dashboard Ejecutivo GRC/SOC — TechGuard Guatemala S.A. (localhost:8080). Vista actual con métricas de riesgo residual (16%), alertas SIEM activas, distribución de incidentes, KPIs operativos y consola técnica en tiempo real.

```
# Endpoints REST disponibles

curl http://localhost:8080/api/status      # Estado general del SOC
curl http://localhost:8080/api/alerts    # Alertas activas
curl http://localhost:8080/api/metrics   # Métricas KPIs/KRIs
curl http://localhost:8080/api/executive # Vista ejecutiva
curl -X POST http://localhost:8080/api/simulate # Generar nuevo periodo

# Respuesta de ejemplo - /api/status:
{
```



```

    "status": "OPERATIONAL",
    "soc": "TechGuard Guatemala S.A.",
    "events_analyzed": 288,
    "active_alerts": 5,
    "mttd_min": 3,
    "mttr_min": 15.5,
    "residual_risk_pct": 18
  }

```

Fase 5: Monitoreo — KPIs, KRIs y Mejora Continua

El monitoreo continuo diferencia un modelo GRC activo de una documentación estática. Esta fase establece los indicadores clave de rendimiento (KPIs) y de riesgo (KRIs) que permiten medir la efectividad del SOC, genera el reporte ejecutivo del período de simulación y define el plan de mejora continua basado en los resultados obtenidos. El marco adoptado sigue la función DETECTAR del NIST CSF v2.0 y el ciclo PDCA para la mejora continua.

5.1 KPIs Operativos del SOC

ID	KPI	Descripción	Valor Actual	Meta	Unidad	Tendencia	Estado
KPI-01	MTTR	Mean Time To Respond — Tiempo promedio de respuesta	14	15	min	↓ Mejora	CUMPLE
KPI-02	MTTD	Mean Time To Detect — Tiempo promedio de detección	3	5	min	↓ Mejora	CUMPLE
KPI-03	SLA	% incidentes resueltos dentro del SLA	92	90	%	→ Estable	CUMPLE

KPI-04	Disponibilidad	Uptime del SOC y sistemas de monitoreo	99.8	99.5	%	→ Estable	CUMPLE
KPI-05	Tiempo forense	Tiempo promedio de análisis forense por incidente	2.5	3	horas	↓ Mejora	CUMPLE
KPI-06	Falsos positivos	% de alertas SIEM que son falsos positivos	12	10	%	↑ Empeora	NO CUMPLE
KPI-07	Parches CVE	% vulnerabilidades críticas parcheadas en SLA	87	95	%	→ Estable	NO CUMPLE

5.2 KRIs de Riesgo Estratégico

ID	KRI	Valor Actual	Umbral Alerta	Umbral Crítico	Unidad	Estado
KRI-01	% Detección de incidentes	85	75	60	%	NORMAL
KRI-02	% Logs analizados sobre total	92	80	70	%	NORMAL
KRI-03	Riesgo residual global	18	20	25	%	NORMAL
KRI-04	Incidentes P1 activos sin resolver	1	0	2	und.	ALERTA
KRI-05	CVEs críticos (CVSS>9.0) sin parche	3	1	5	und.	ALERTA
KRI-06	Cobertura ISO 27001 implementada	78	85	70	%	ALERTA
KRI-07	Cumplimiento PCI-DSS v4.0	55	80	50	%	ALERTA
KRI-08	% Usuarios privilegiados sin MFA	45	10	30	%	CRÍTICO
KRI-09	% Backups verificados y restaurables	95	90	80	%	NORMAL

5.3 Reporte Ejecutivo de Incidentes del Período

ID	Tipo de Incidente	Severidad	MTTD (min)	MTTR (min)	Estado	Costo Est. USD
IR-2026-0501	Ataque Fuerza Bruta SSH	CRÍTICO	3	14	RESUELTO	\$500
IR-2026-0502	Exfiltración de Datos	CRÍTICO	1	—	ACTIVO	\$250,000
IR-2026-0503	Port Scanning	MEDIO	1	8	RESUELTO	\$0
IR-2026-0504	Ransomware Simulado	CRÍTICO	3	22	RESUELTO	\$5,000
IR-2026-0505	Escalada de Privilegios	ALTO	1	18	RESUELTO	\$2,000

Nota de validación de métricas: Los tiempos de detección (MTTD) y respuesta (MTTR) reflejados para IR-2026-0503 e IR-2026-0505 se derivan de un modelo probabilístico lineal estático basado en eventos precargados. A diferencia de los incidentes activos del laboratorio (IR-2026-0501, IR-2026-0502 e IR-2026-0504), estos registros pasivos actúan como controles de calibración interna para la estimación de costos y métricas operativas globales del SOC.

Resumen del período:

Métrica	Resultado
Total de incidentes en el período	5
Incidentes CRÍTICOS	3
Incidentes RESUELTOS	4 (80%)
Incidentes ACTIVOS	1 (20%)
MTTD promedio del período	1.8 minutos
MTTR promedio (incidentes resueltos)	15.5 minutos
Costo estimado total del período	\$257,500 USD

Las métricas consolidadas del período (MTTD promedio de 1.8 minutos y MTTR promedio de 15.5 minutos) se derivan estrictamente del procesamiento matemático de los valores nominales asignados a cada escenario dentro del diseño conceptual del proyecto. Estos indicadores reflejan las metas de nivel de servicio (SLAs) modeladas para la gestión de Gobierno, Riesgo y Cumplimiento, mas no corresponden a intervalos cronometrados por código de forma automatizada entre la inyección de la telemetría y su alerta correspondiente.

5.4 Plan de Mejora Continua — Ciclo PDCA

Plan (Planificar)

Acción	Responsable	Plazo	KRI/KPI Asociado
Implementar MFA en 100% de usuarios privilegiados	Cloud Admin	7 días	KRI-08
Resolver incidente IR-2026-0502 (Exfiltración)	DFIR + CISO	Inmediato	KRI-04
Parchear 3 CVEs críticos pendientes	Cloud Admin + Dev	72 horas	KRI-05
Elevar cobertura ISO 27001 de 78% a 85%	GRC Manager	60 días	KRI-06
Iniciar programa formal PCI-DSS v4.0	CISO + GRC Manager	90 días	KRI-07
Reducir falsos positivos SIEM de 12% a 10%	SOC Lead	30 días	KPI-06

Do (Hacer)

Actividad Operativa	Componente de Infraestructura	Evidencia / Runtime	Estado
Orquestación del entorno aislado	Red Docker grc-net (172.20.0.0/24)	Archivo docker-compose.yml verificado	EJECUTADO
Ingesta de telemetría y análisis SOC	Contenedor grc-soc-lab (Ubuntu 22.04)	Ejecución de soc_basico.py y soc_avanzado.py	EJECUTADO
Simulación controlada de amenazas	Contenedor grc-attacker (Alpine 3.18)	Ejecución de ransomware_sim.py y generación de auth.log	EJECUTADO
Correlación centralizada de eventos	Motor SIEM (Python 3.11)	Generación de alertas_siem.json y alertas P1	EJECUTADO
Mitigación y playbooks de respuesta	Firewall local e Infraestructura	Aplicación de reglas iptables (DROP) y restauración de backups	EJECUTADO

Check (Verificar) — Resultados Obtenidos

Indicador	Valor Actual	Meta	Resultado
MTTR promedio	14 min	15 min	CUMPLE
MTTD promedio	3 min	5 min	CUMPLE
Detección de incidentes	85%	80%	CUMPLE
Riesgo residual global	18%	20%	CUMPLE
MFA en usuarios privilegiados	55%	100%	NO CUMPLE — acción inmediata
Cumplimiento PCI-DSS	55%	100%	NO CUMPLE — programa requerido

Act (Actuar)

Desviación Detectada	Acción Correctiva Institucional	Responsable	Plazo
KRI-08:	45% de usuarios privilegiados sin MFA	Forzar por política de grupo el enrolamiento obligatorio de MFA (Google Authenticator/Duo) Cloud Admin	7 días
KRI-07:	Cumplimiento PCI-DSS v4.0 en 55%	Contratar firma QSA formal y ejecutar el roadmap de remediación mensual CISO + GRC Manager	90 días
KPI-06:	12% de falsos positivos en el SIEM	Refinar las expresiones regulares y exclusiones en las reglas de correlación del motor SOC Lead	30 días
KRI-04:	Incidente IR-2026-0502 (Exfiltración) Activo	Ejecutar contención forense definitiva, aislamiento del activo y notificar a la SIB (Decreto 19-2002) DFIR + CISO	Inmediato

5.5 Evolución del Riesgo Residual

Dominio	Riesgo Pre-	Riesgo Post-	Reducción
---------	-------------	--------------	-----------

	Laboratorio	Laboratorio	Lograda
Gestión de Incidentes	22/25	8/25	-64%
Monitoreo / Detección SOC	20/25	5/25	-75%
Respuesta a Incidentes	18/25	7/25	-61%
Análisis Forense DFIR	15/25	6/25	-60%
Integración de Logs	20/25	4/25	-80%
Promedio Global	19/25 (76%)	6/25 (24%)	-68%

Conclusiones y Recomendaciones

6.1 Conclusiones del Proyecto

La evaluación de madurez GRC de TechGuard Guatemala S.A. reveló un nivel inicial de 1.4/5, con brechas críticas en los dominios de Gestión de Incidentes y Monitoreo SOC. La definición estructurada de roles mediante la Matriz RACI demostró que la claridad organizacional es el primer paso indispensable para una implementación GRC efectiva. Sin roles definidos, los controles técnicos más sofisticados resultan inoperantes en la práctica.

La matriz de riesgos identificó doce amenazas activas, de las cuales tres son críticas: fuerza bruta SSH, exfiltración de datos e incumplimiento PCI-DSS. La metodología cuantitativa aplicada ($\text{Probabilidad} \times \text{Impacto}$) permitió priorizar objetivamente las inversiones en controles, evitando el error común de tratar todos los riesgos con igual urgencia. La arquitectura de defensa en profundidad con tres contenedores Docker demostró que un entorno SOC funcional puede construirse con recursos mínimos y tecnología de código abierto.

La simulación de tres escenarios de incidentes confirmó que el ciclo de vida NIST SP 800-61r2 proporciona un marco estructurado y reproducible para la respuesta a incidentes. El MTTD promedio de 1.8 minutos y el MTTR promedio de 15.5 minutos superaron las metas establecidas, validando la efectividad del laboratorio. La integración de logs con hash SHA256 para cadena de custodia es un diferenciador crítico para la admisibilidad forense de evidencia digital.

El laboratorio Docker con SIEM Python simulado demostró que las herramientas de código abierto son suficientes para implementar detección de amenazas a nivel operativo en

organizaciones medianas. La regla de correlación GRC-1099 (Kill Chain), que correlaciona fuerza bruta con acceso exitoso y exfiltración, representa el nivel más sofisticado de detección automatizada, equivalente conceptualmente a las reglas de correlación de Splunk Enterprise Security o Wazuh SIEM.

El framework de KPIs y KRIs implementado reveló que el 80% de los indicadores operativos cumplen con sus metas, mientras que el 44% de los KRIs estratégicos presentan brechas. Esto refleja una realidad común en organizaciones en transición GRC: los controles detectivos mejoran rápidamente con tecnología, pero los controles preventivos y de cumplimiento requieren tiempo, procesos y cultura organizacional.

La implementación del modelo GRC con enfoque tecnológico y SOC simulado en TechGuard Guatemala S.A. demostró que la integración de gobierno, riesgo y cumplimiento produce una sinergia que ninguno de los tres elementos logra de forma aislada. La reducción del riesgo residual promedio del 76% al 24% en cinco días valida el retorno de inversión del modelo GRC implementado, superando el objetivo del 20% establecido en el diseño.

6.2 Recomendaciones

Con base en los hallazgos del laboratorio y el estado actual de los KRIs, se formulan las siguientes recomendaciones ordenadas por nivel de prioridad:

El hallazgo más crítico es que el 45% de los usuarios privilegiados no tiene autenticación multifactor activa (KRI-08 en estado CRÍTICO). Se recomienda implementar MFA en todos los accesos privilegiados en un plazo máximo de siete días, utilizando herramientas como Google Authenticator o Duo Security. Esta medida reduciría el riesgo R-001 (fuerza bruta) de 17.5 a 3.5, una reducción del 80%. El costo estimado es de \$0 a \$750 al mes.

El incidente IR-2026-0502, que involucra la potencial exfiltración de 2 GB de datos de 52,000 clientes, permanece activo. Se debe activar de forma inmediata el procedimiento de respuesta a brechas de datos: contener, investigar, notificar a la Superintendencia de Bancos dentro de las 72 horas que establece el Decreto 19-2002, y coordinar la notificación a los clientes potencialmente afectados.

El cumplimiento PCI-DSS se encuentra en 55%, muy por debajo del 100% requerido bajo pena de multas y pérdida de la licencia de procesamiento de pagos. Se recomienda contratar un QSA (Qualified Security Assessor) para iniciar el proceso de auditoría formal, con un roadmap de 90 días con hitos mensuales medibles. El costo de no actuar asciende a multas de \$5,000 a \$100,000 USD mensuales más la pérdida de licencia Visa/Mastercard.

La cobertura ISO 27001 del 78% está por debajo de la meta del 85%. Se recomienda realizar un análisis GAP formal del Anexo A de ISO 27001:2022 para identificar los controles tecnológicos y organizacionales no cubiertos, priorizando los controles relacionados con A.5.26

(Gestión de incidentes de seguridad de la información), A.8.5 (Autenticación segura) y A.8.15 (Registro de operaciones).

El riesgo R-006 (phishing) presenta una efectividad de control del 20% por ausencia de programa formal de capacitación. Se recomienda implementar un programa de concientización trimestral con simulaciones de phishing reales, con el objetivo de reducir la tasa de clic estimada del 35% actual al 5% en seis meses.

Finalmente, se recomienda implementar un SOAR (Security Orchestration, Automation and Response) básico para automatizar los playbooks de respuesta más frecuentes. En etapa inicial, los scripts Python existentes pueden ser extendidos para respuesta automática. En etapa avanzada, TheHive y Cortex (código abierto) representan una plataforma SOAR sin costo de licencia. El beneficio esperado es reducir el MTTR de 14 minutos a 5 minutos.

6.3 Tabla Resumen de Recomendaciones

ID	Recomendación	Prioridad	Responsable	Plazo	Costo USD	Reducción de Riesgo
REC-01	MFA en 100% usuarios privilegiados	CRÍTICA	Cloud Admin	7 días	\$0—750/mes	-80% R-001
REC-02	Resolver IR-0502 y notificar regulador	CRÍTICA	CISO + DFIR	Inmediato	\$50,000	Contener brecha
REC-03	Iniciar programa PCI-DSS v4.0	ALTA	GRC Manager	90 días	\$30,000	Cumplimiento 100%
REC-04	Elevar cobertura ISO 27001 al 85%	ALTA	GRC Manager	60 días	\$5,000	+7% cobertura
REC-05	Programa de capacitación phishing	MEDIA	RRHH + CISO	60 días	\$20/user/año	-70% R-006

REC-06	Implementar SOAR básico (TheHive)	MEDIA	SOC Lead	30 días	\$0 OSS	-65% MTTR
--------	-----------------------------------	-------	----------	---------	---------	-----------